



中华人民共和国通信行业标准

YD/T XXXX—XXXX

5G 移动通信网 数据安全监测预警技术要求

5G mobile network technical requirements for data security monitoring and early
warning

（报批稿）

××××-××-××发布

××××-××-××实施

中华人民共和国工业和信息化部 发布

目 次

前 言..... II

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 缩略语 1

5 数据安全监测预警概述 1

 5.1 概述 1

 5.2 数据安全监测预警框架 2

6 数据安全监测 2

 6.1 监测信息采集 2

 6.2 监测信息处理 4

7 数据安全预警 4

 7.1 预警事件 4

 7.2 预警信息推送及管理 5

8 监测与预警展示 6

 8.1 监测信息展示 6

 8.2 预警展示 6

9 监测预警信息安全防护 6

附 录 A （资料性） 数据流转监测预警实施..... 7

 A.1 用户通信业务流程中的数据监测预警..... 7

 A.2 网元存储敏感数据的监测预警..... 7

参 考 文 献..... 8

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国移动通信集团有限公司、中国信息通信研究院、华为技术有限公司、中兴通讯股份有限公司、上海诺基亚贝尔股份有限公司、北京东方通网信科技有限公司、中国联合网络通信集团有限公司、博鼎实华(北京)技术有限公司。

本文件主要起草人：杨亭亭、陆黎、吕临颖、粟栗、耿慧拯、齐旻鹏、袁琦、胡力、林兆骥、游世林、吴荣、崔婷婷、高枫、葛诗新、靳涛、顾希。

5G 移动通信网 数据安全监测预警技术要求

1 范围

本文件规定了5G移动通信网中数据安全监测预警技术要求，包括监测信息采集、处理，预警事件、预警方式，监测预警信息展示与安全保护。

本文件适用于指导安全管理、安全运营人员对5G移动通信网中的数据安全事件进行发现和处理。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

- GB/T 36635-2018 信息安全技术 网络安全监测基本要求与实施指南
- GB/T 41479-2022 信息安全技术 网络数据处理安全要求

3 术语和定义

下列术语和定义适用于本文件。

3.1

数据安全事件 data security events

由单个或一系列意外或有害的数据安全事态所组成，极有可能造成数据泄露、数据丢失、数据损坏等严重后果的事件。

4 缩略语

下列缩略语适用于本文件。

- AMF 接入和移动性管理功能（Access and Mobility Management Function）
- gNB 下一代基站（generation nodeB）
- IP 网际互连协议（Internet Protocol）
- MANO 管理和编排（Management and Orchestration）
- MEC 移动边缘计算（Mobile Edge Computing）
- SMSF 短信服务功能(Short Message Service Function)

5 数据安全监测预警概述

5.1 概述

数据安全典型事件包括数据泄露、数据丢失、数据篡改、数据损坏等。造成这些安全事件的原因通常包括数据非法导出、非法删除，传输过程中被截获，共享数据遭到非法转售等。为了防止或及时发现数据安全事件的发生，应对用户的数据访问、数据导出、数据传输等重要操作进行监测，对其中的风险操作进行预警。

数据安全监测对象为5G网络中收集、存储、处理数据的网元以及相关存储、处理平台，包括5G网元、网管系统、网络云等。对上述系统间的数据流转过程进行监测，对监测过程中发现的可能引起数据安全事件的异常行为，以及已经发生的数据安全事件预警。

5.2 数据安全监测预警框架

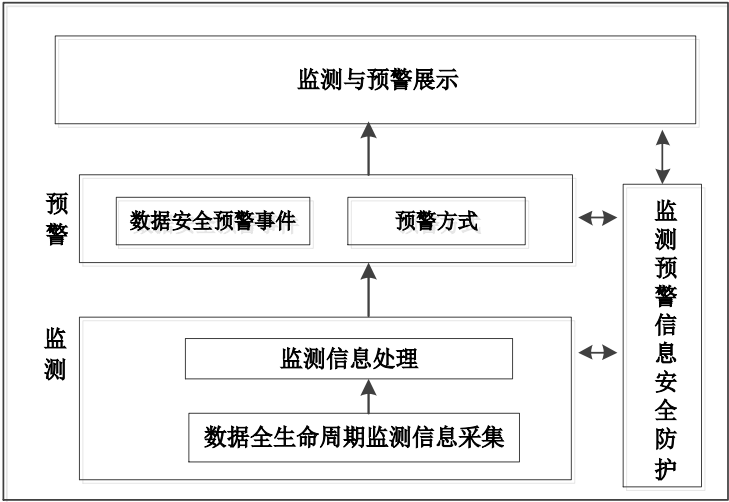


图 1 数据安全监测预警框架

数据安全预警框架如图1所示，包括监测、预警、监测与预警展示和监测预警信息安全防护。其中监测和预警为核心，指导监测信息采集、数据处理以及预警活动的开展。监测与预警展示主要将监测与预警内容以可视化形式进行展示，便于运维人员查看与处理。监测预警信息安全防护为监测预警信息的存储、处理提供安全保护，通常可通过监测预警系统实现。

6 数据安全监测

6.1 监测信息采集

6.1.1 数据全生命周期监测信息采集

针对5G网络中数据流转的各个环节，展开监测信息采集：

- a) 数据采集环节：
 - 1) 数据采集指 5G 网络自身创建数据或从外部获取数据的行为，其中数据创建主要指数据配置以及系统运行过程中产生数据。控制面数据采集主要包括网元创建数据，以及在 4/5G 互操作等场景，5G 网络从他网获取数据；管理面数据采集主要包括网元、MANO、切片管理系统等创建数据以及获取外部导入数据的行为；用户面数据采集指 5G 网络从其他网络、终端设备采集数据，以及通过分析产生新的用户数据的行为；
 - 2) 数据采集环节应对网元、MANO、切片管理系统的数据创建操作、数据导入行为等进行监测。监测方式主要依靠系统的操作日志、安全日志分析；
 - 3) 应采集网元、MANO、切片管理系统等对象的操作日志，针对数据导入导出、数据写入等重点操作，分析操作账号、操作时间、操作行为量等。
- b) 数据传输环节：
 - 1) 此环节的数据安全监测主要针对 5G 网络内部的数据传输，主要包括 MANO 内部组件之间数据传输、MANO 与网元基础设施层间数据传输、切片管理系

统内部数据传输，以及切片管理系统与 MANO、第三方平台及运营商业支撑系统间数据传输等；

注：MANO 各组件封装后整体提供时，可不对各组件之间的传输进行监测。

- 2) 数据传输环节对 MANO、网元、切片管理系统、第三方平台及运营商业支撑系统等系统之间的传输进行监测，应包括传输的时间、IP 等，可通过接口日志获得。
- c) 数据存储环节：
 - 1) 数据存储指 5G 网络中数据存储过程。主要涉及具有存储能力的网元、切片管理系统、网管系统和 MEC 平台等；
 - 2) 数据存储环节主要保障数据存储安全，需要监测数据的访问情况，涉及的操作主要包括基础的查询、新增、更新、删除等，监测信息主要通过操作日志获得，包括操作账号、登录时间、操作行为、访问的数据对象等。
- d) 数据使用环节：
 - 1) 数据使用指网元、切片管理系统、网管系统和 MEC 平台等系统的计算、分析等操作；
 - 2) 数据使用环节的监测信息，主要从上述系统的用户操作日志中获得，应包括操作账号、操作时间、操作行为等。
- e) 数据共享环节：根据 GB/T 41479-2022 中 5.7 等相关要求，数据共享前需进行安全影响分析、风险评估和脱敏处理等，一般由组织机构的信息技术网络经处理后提供，不从 5G 移动通信网络直接共享，因此暂不考虑对数据共享环节的监测和安全预警。
- f) 数据删除环节：
 - 1) 5G 数据删除通常发生在虚拟机迁移、虚拟网元下线，物理设备退服等场景；
 - 2) 5G 网络中需监测虚拟机迁移、虚拟网元下线后的磁盘逻辑删除操作，通过平台操作日志进行分析，包括操作账号、时间、删除方式等。针对物理设备（涉及磁带、硬盘、光盘等）删除场景，其监测主要通过人员监督方式进行。

6.1.2 采集方式

应支持对流量和日志的实时、非实时采集，数据生命周期各个环节采集方式如下：

- a) 数据采集阶段：主要获取采集接口的操作日志和安全日志进行分析，主要涉及网元与网元之间的接口、MANO 组件之间接口等，日志信息不全时通过接口的流量分析进行补充；
- b) 数据传输：传输阶段主要获取传输接口和设备日志分析数据传输活动，日志信息不全时通过传输的流量分析进行补充。主要涉及网元之间数据传输，终端与 gNB 之间数据传输等，其中涉及终端与接入网进行数据传输时，日志信息通过接入网侧获取；
- c) 数据存储：存储阶段主要获取存储平台的操作日志，对存储行为进行分析监测，包括网元、切片管理系统、MEC 平台等；
- d) 数据使用：使用阶段主要获取应用平台的操作日志，以及外部接入应用的接口日志，对数据使用行为进行分析监测。主要包括网元、切片管理系统、网管系统和 MEC 平台等；
- e) 数据删除：删除阶段主要获取存储平台的操作日志，对删除操作进行分析。主要包括网元、切片管理系统、MEC 平台等具有数据存储功能的平台。

6.2 监测信息处理

6.2.1 数据清洗

通过数据清洗解决收集的日志数据存在的空值、缺失值以及数据大量冗余、错误数据、无效数据等问题，以便开展日志分析。数据清洗应满足以下功能：

- a) 空值、缺失值清洗：大多数情况下，缺失的值必须手工填入，某些缺失值可以从本数据源进行推导或使用其他数据源平均值、最大值、最小值或更为复杂的概率估计代替；
- b) 消除冗余数据：利用唯一性的字段对冗余数据进行过滤。也可按主键去重，或按规则去重，编写一系列的规则，对重复情况复杂的数据进行去重；
- c) 错误值检测处理：使用统计分析的方法识别可能的错误值或异常值，如偏差分析、识别不遵守分布或回归方程的值；使用简单规则库（常识性规则、业务特定规则等）检查数据值；使用不同属性间的约束，检查字段间的相关关系。

6.2.2 数据转换

数据转换应支持在不同日志中字段名相同含义不同、相同字段数据类型不同、相同信息字段名不同等情况下，对日志数据进行转换，实现数据规范化。数据转换可支持以下技术：

- a) 数据类型转换：将一种类型的数据转换成另一种类型的数据，类型转换的前提是类型相容；
- b) 日期/时间格式的转换：对于采用不同日期和时间格式的情况，通过手工程序编码等方式转换成统一格式；
- c) 重新格式化：将许多以不同方式存储在不同数据源中的信息转换成统一的表达方式。一般有字段值的拆分和合并，可利用基于正则表达式匹配、键值或符号分割方式将字段值拆分；也可将多个字段值按照标准合并成所需字段值。

6.2.3 数据解析

对监测信息的处理主要集中在对日志和流量信息的解析，应满足以下要求：

- a) 从实时性上，应支持对日志、流量的实时和非实时解析；
- b) 从内容和格式角度开展对日志的解析：
 - 1) 内容：支持对日志中的监测数据对象、操作、时间等字段内容进行识别；
 - 2) 格式：支持对基于空格、制表符、逗号、分号等分隔符的日志进行分析处理，同时应支持对无分隔符的日志进行结构化处理。
- c) 从内容和格式角度开展对流量的解析：
 - 1) 内容：支持对流量数据中的监测数据进行识别，对操作命令、时间等属性进行提取；
 - 2) 格式：支持将流量数据根据统一日志格式进行结构化处理。

7 数据安全预警

7.1 预警事件

对发现的数据安全事件以及可能造成数据安全事件的异常行为进行预警：

- a) 数据采集：
 - 1) 对系统采集账号进行异常行为分析，包括操作时间、采集设备接入行为等，当发生异常时间采集、超量采集、恶意设备接入采集、违规数据源接入等行为，

以及已经确认的数据采集过程中的数据窃取等事件进行预警；

- 2) 异常时间采集、超量采集可能由账号盗用或采集需求临时改变引起，可能会造成数据泄露，需告警后对账号行为进行进一步判断；
- 3) 恶意设备接入采集属于非法接入采集数据，按照已经引起数据泄露进行预警；
- 4) 违规数据源接入属于非法采集数据，可能使得系统采集到非法数据信息影响正常业务数据，按照数据损坏或数据违规导入进行预警。

b) 数据传输：

- 1) 在数据传输环节，主要对传输时间、接口调用频次等进行分析，当发生异常时间传输，数据流量异常，接口超频次调用等行为时进行预警，并对传输过程中发现的数据窃取等行为进行预警；
- 2) 异常时间传输，数据流量异常，接口超频次调用等可能由账号被盗用、操作人员非法操作或传输需求改变导致，若账号被盗用或操作人员非法操作，上述异常行为可能导致数据泄露，需告警后对异常行为进行进一步判断；
- 3) 传输过程中发生中间人攻击等行为属于已经造成数据泄露，应进行预警。

c) 数据存储：

- 1) 在数据存储环节，主要对数据的导入、查询、修改、删除，以及备份数据的存储等行为进行分析，对数据导入量异常、数据修改时间异常、数据批量删除、数据库删除等操作进行预警；
- 2) 数据导入异常可能造成系统存储非法数据，需预警后对存储的内容进行进一步分析；
- 3) 数据修改时间、修改量异常可能属于数据非法访问或修改需求改变，可能会造成数据泄露需预警后对存储的内容进一步分析判断；
- 4) 核心数据、重要数据及用户隐私信息等批量删除属于敏感度较高的操作，极有可能造成数据丢失，需预警后进一步分析判断；
- 5) 运行中的业务系统数据库删除操作属于高危险性操作，按照数据破坏进行预警。

d) 数据使用：

- 1) 对访问账号的访问时间、操作权限、登陆 IP、针对监测数据的批量导出等行为进行分析，对异常 IP 地址登陆、访问时间异常、数据操作异常等进行预警，同时对数据使用过程中发现的数据丢失、数据损坏等情况进行预警；
- 2) 异常 IP 地址登陆、访问时间异常、数据操作异常可能引起数据泄露，需预警后进一步判断。其中，通过日志及流量分析可对数据的流转及使用情况有针对性监测，对数据的监测预警实施流程见附录 1；
- 3) 数据使用分析过程中可能发现读取的数据不存在、数据被损坏或混有虚假数据等情况，对此类事件进行预警。

- e) 数据删除：在数据删除环节，主要对于删除对象错误、异常时间操作、逻辑清除不彻底等进行预警。针对物理删除操作，通过审计删除记录发现其中的不合规行为。

7.2 预警信息推送及管理

应支持采用不同方式、不同时间进行预警信息推送，对预警策略和预警信息进行管理，具体包括：

- a) 支持对告警信息进行实时和非实时推送，推送的告警信息包括告警事件、级别、发生时间、处置建议等；；
- b) 告警信息支持界面展示并通过邮件、短信、即时通信等方式发送给相关负责人；
- c) 支持管理员对告警策略进行管理，调整告警事件及方式；

- d) 告警信息存储时间遵循日志信息保存要求，至少存储 6 个月；
- e) 支持预警信息与处理手段的联动，如对超频次调用接口提供阻断处理。

8 监测与预警展示

8.1 监测信息展示

监测信息展示应包括对原始日志信息展示、对监测信息的多维度统计展示和预警策略的展示。其中对原始日志信息的展示应包括收集时间、数据来源、采集方式、存储位置等，监测信息统计应支持基于时间维度、数据源维度、格式维度的统计，以及多维度组合统计

8.2 预警展示

应支持：

- a) 对预警信息的实时界面展示；
- b) 对预警信息进行不同维度的统计展示，包括时间维度、用户维度、级别维度等。

9 监测预警信息安全防护

监测预警信息的安全保护应支持：

- a) 国家、行业规定的重要数据、核心数据加密存储；
- b) 对监测过程中收集的原始数据、预警信息等进行安全存储，为保证时效性，至少保存 6 个月；
- c) 对存储的数据制定细粒度的访问控制策略；
- d) 具备口令强度策略、口令强度自动核查及用户超时退出机制；
- e) 监测自身运行状态，并对异常状态进行告警；
- f) 对系统配置等重要信息进行备份，以便系统发生故障时能够快速恢复；
- g) 支持标准时间自动同步，每天至少同步一次；
- h) 其他自身防护要求按照 GB/T 36635-2018 的要求执行。

附录 A

(资料性)

数据流转监测预警实施

A.1 用户通信业务流程中的数据监测预警

在开展日常数据安全监测预警的基础上,可结合数据自动识别技术,对监测数据的流转和访问情况开展专门的监测和展示:

- a) 业务情况描述: 用户使用手机终端编辑并发送短信, 短信内容具有个人身份证号码等敏感信息;
- b) 数据流转情况: 数据经空口和 gNB 传输至 AMF, 然后由 AMF 转发到 SMSF, 通过 SMSF 传输到短消息中心, 再由短消息中心经相反流程转发到目标用户;
- c) 数据监测根据数据流转情况可分为以下步骤:
 - 1) 监测预警系统采集 gNB 等接口日志, 对日志进行结构化处理后, 开展日常监测, 分析是否有接口流量异常等行为、非法访问等行为;
 - 2) 数据到达 AMF 进行存储使用。监测预警系统采集 AMF 操作日志, 得到这条短信的内容、网元操作行为、操作时间等信息。通过数据自动识别, 发现此条短信内容含有敏感信息, 可对此条短信进行重点监测(若数据传输时未进行加密, 可在步骤 1)通过流量分析识别其中的敏感信息)。分析网元对此内容的操作频率、操作时间等是否符合操作基线, 系统对此数据是否有越权访问等行为, 对异常行为进行告警;
 - 3) 数据由 AMF 转发到 SMSF 进行存储使用。监测预警系统通过分析 AMF 的数据使用命令发现此条含有此敏感信息的短信转发到 SMSF, 对 SMSF 的日志进行采集并分析数据存储、访问情况, 对异常行为进行告警;
 - 4) 数据由 SMSF 传输到短消息中心的监测过程与步骤 c)相同。
- d) 数据安全监测展示: 针对指定数据的定向监测, 可将多个网元或存储系统的日志及监测情况进行关联, 展示数据的流向和存储访问情况。

A.2 网元存储敏感数据的监测预警

用户身份标识、鉴权信息等数据在 AMF 等网元进行存储及分析, 网元中所存储数据使用监测也是监测预警的重要环节, 包括以下功能:

- a) 网元存储数据扫描及展示: 结合数据自动识别技术, 对网元存储的数据进行扫描, 发现其中的敏感信息, 如用户身份信息、基站信息等, 建立清单并进行不同维度的展示;
- b) 数据使用情况监测: 对网元的访问命令及操作日志进行分析, 发现其中对指定数据的访问, 审计访问操作是否符合权限、访问时间等要求, 对异常行为进行告警;
- c) 数据使用情况展示: 通过对数据访问行为的监测, 可针对指定的数据展示其访问量、常用访问时间、常用操作行为等信息。

参 考 文 献

- [1] GB/T 25069—2022 信息安全技术 术语
 - [2] GB/T 37973—2019 信息安全技术 大数据安全管理指南
 - [3] GB/T 37988—2019 信息安全技术 数据安全能力成熟度模型
 - [4] YD/T 3801—2020 电信网和互联网数据安全风险评估实施方法
 - [5] YD/T 3813—2020 基础电信企业数据分类分级方法
 - [6] 国家互联网信息办公室，数据出境安全评估办法，2022 年 7 月 7 日
-